

PLAN DE ACCION - ETAPA 1

Portal de Licitaciones para Empresa Privada

Arquitectura Debian + TypeScript + PostgreSQL

Version	1.2 - Ajustada a Debian, TypeScript y PostgreSQL
Alcance	Primera etapa / MVP funcional
Contexto de negocio	Licitaciones privadas con visibilidad inmediata de ofertas para usuarios internos autorizados
Regla critica	Aislamiento total entre proveedores: no ven participantes, valores, cantidades, ranking ni ofertas de terceros
Fecha de preparacion	2 de julio de 2026

Este documento transforma el proyecto funcional del portal de licitaciones en un plan de accion ejecutable para iniciar desarrollo de la primera etapa. Incluye requerimientos funcionales, requerimientos tecnicos, frontend, backend, infraestructura, base de datos, seguridad, hardware, herramientas, fases, criterios de aceptacion y fuentes oficiales de consulta.

Indice ejecutivo

1. 1. Proposito y alcance de la primera etapa
2. 2. Supuestos de negocio obligatorios
3. 3. Decisiones tecnologicas base
4. 4. Arquitectura objetivo MVP
5. 5. Requerimientos funcionales por modulo
6. 6. Requerimientos frontend
7. 7. Requerimientos backend y API
8. 8. Modelo de datos minimo
9. 9. Seguridad, permisos y auditoria
10. 10. Infraestructura, hardware y despliegue en Debian
11. 11. Herramientas, aplicaciones y ambientes
12. 12. Plan de ejecucion por fases y sprints
13. 13. Pruebas, criterios de aceptacion y salida a produccion
14. 14. Preparacion para etapas 2, 3 y 4
15. 15. Fuentes oficiales consultadas

1. Proposito y alcance de la primera etapa

El objetivo de la Etapa 1 es implementar un MVP funcional, seguro y auditable para gestionar licitaciones privadas de punta a punta, evitando complejidad enterprise innecesaria. La plataforma debe permitir publicar licitaciones, registrar y habilitar proveedores, recibir consultas, recibir ofertas, visualizar ofertas internamente desde el momento de envio, evaluar, adjudicar o cancelar, y conservar evidencia documental.

La primera etapa no debe intentar resolver todo el ciclo avanzado de compras. Debe resolver correctamente el flujo critico minimo: publicacion, participacion controlada, oferta, evaluacion, decision y auditoria.

1.1 Resultado esperado

- Portal web responsive para proveedores.
- Panel interno para compras, evaluadores, aprobadores y auditoria.
- Backend API desarrollado en TypeScript.
- Base de datos PostgreSQL.
- Servicio desplegable sobre Debian estable.
- Carga y descarga controlada de documentos.
- Aislamiento absoluto de informacion entre proveedores.
- Auditoria basica de eventos criticos, especialmente visualizacion y descarga de ofertas.
- Backups diarios y restauracion probada en ambiente de staging.

1.2 Fuera de alcance de la Etapa 1

- Subastas inversas o negociacion dinamica.
- Integracion con SAP, ERP, contabilidad o ordenes de compra.
- Firma digital avanzada o firma cualificada.
- SSO corporativo, MFA obligatorio generalizado y directorio LDAP/AD.
- Alta disponibilidad multi-nodo.
- BI avanzado, dashboards gerenciales complejos u OCR documental.
- Apertura diferida de ofertas: no aplica por regla de negocio definida.
- Publicacion de valores de adjudicacion o ranking a proveedores.

2. Supuestos de negocio obligatorios

Estas reglas condicionan el diseno del sistema y deben estar implementadas desde el primer sprint funcional. No deben quedar como configuraciones opcionales sin control.

Codigo	Regla	Descripcion
RN-01	Visibilidad interna inmediata	Una vez que el proveedor envia su presupuesto/oferta, los usuarios internos autorizados pueden ver datos, items, valores y documentos.
RN-02	Sin apertura diferida	No se implementa el mecanismo de cartas/ofertas cerradas hasta una fecha de apertura. La fecha limite solo bloquea

		nuevas presentaciones o reemplazos.
RN-03	Aislamiento entre proveedores	Un proveedor nunca puede ver valores, archivos, datos, cantidad de ofertas, ranking ni participantes de la misma licitacion.
RN-04	Vista proveedor restringida	El proveedor solo ve informacion publicada de la licitacion, sus propias consultas, respuestas permitidas y sus propias ofertas.
RN-05	Trazabilidad de acceso interno	Cada visualizacion o descarga interna de una oferta debe quedar auditada con usuario, fecha, hora, IP y accion.
RN-06	Bloqueo por plazo	El sistema no acepta nuevas ofertas ni reemplazos despues del cierre configurado.
RN-07	Homologacion manual inicial	El proveedor se registra, pero su habilitacion para ofertar depende de validacion manual de la empresa.
RN-08	Addendas trazables	Cualquier cambio de bases, plazos, items o condiciones debe quedar registrado como addenda/version.
RN-09	No eliminacion fisica	Documentos, ofertas y logs no deben eliminarse fisicamente desde la interfaz; usar anulacion logica con motivo.
RN-10	Decision documentada	Toda adjudicacion, cancelacion o declaracion desierta requiere motivo y responsable.

3. Decisiones tecnologicas base

Para la Etapa 1 se recomienda un monolito modular con API backend en TypeScript, frontend en React + TypeScript y persistencia en PostgreSQL. Esta arquitectura reduce complejidad operativa y permite evolucionar posteriormente hacia integraciones o servicios separados sin rediseñar el negocio.

Capa	Tecnologia	Justificacion
Sistema operativo	Debian stable	Servidor base de produccion. Usar rama stable por enfoque de estabilidad y mantenimiento.
Frontend	React + TypeScript + Vite	Interfaz proveedor e interna con componentes tipados y build rapido.
Backend	NestJS + TypeScript	API modular, arquitectura por modulos, controladores, servicios, guards y validaciones.
Base de datos	PostgreSQL	Relacional, consistente y adecuada para trazabilidad, auditoria y relaciones complejas.
ORM / migraciones	Prisma ORM	Modelo tipado, migraciones y cliente TypeScript para PostgreSQL.
Contenedores	Docker Compose	Orquestacion simple para backend, frontend, PostgreSQL, Nginx y servicios auxiliares.
Proxy / TLS	Nginx	Reverse proxy, HTTPS, limites de carga, cabeceras y publicacion segura.
Archivos	Filesystem controlado en Etapa 1	Guardar fuera del webroot; preparar abstraccion para migrar a MinIO/S3 en Etapa 2.
Autenticacion	JWT o cookies HttpOnly seguras	Elegir una estrategia y aplicarla de forma uniforme; mantener expiracion y renovacion controlada.
Auditoria	Tabla audit_log + logs de aplicacion	Registro funcional consultable y logs tecnicos para soporte.

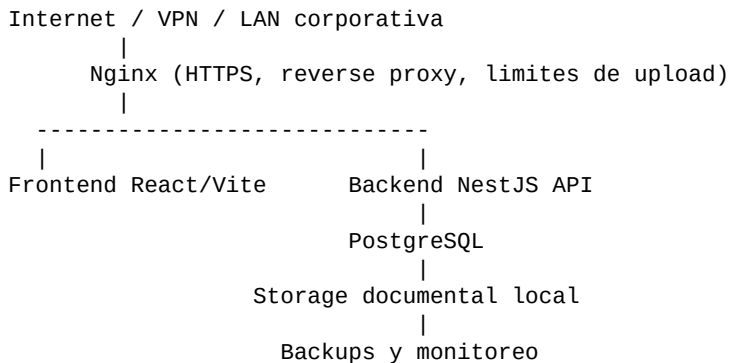
3.1 Recomendacion de stack final

- **Frontend:** React 19 + TypeScript + Vite + React Router + TanStack Query o equivalente para manejo de estado servidor.
- **Backend:** NestJS sobre Node.js LTS, TypeScript estricto, Prisma ORM y PostgreSQL.
- **Infraestructura:** Debian stable, Docker Compose, Nginx, certificados TLS, firewall, backups y monitoreo.
- **Seguridad:** RBAC en backend, validacion de entrada, carga segura de archivos, logs de auditoria y pruebas de autorizacion.

4. Arquitectura objetivo MVP

La arquitectura recomendada para primera etapa es servidor unico con separacion logica por contenedores. Es suficiente para piloto y produccion inicial, siempre que existan backups, monitoreo y controles de acceso correctos.

Diagrama logico:



4.1 Principios de arquitectura

- Monolito modular antes que microservicios.
- Permisos aplicados en backend y no solo en frontend.
- APIs versionables desde el inicio: /api/v1/.
- Archivos privados servidos por backend o enlaces temporales, nunca por path publico directo.
- Tablas de auditoria separadas de logs tecnicos.
- Migraciones versionadas en repositorio.
- Configuracion por variables de entorno, sin secretos en Git.
- Ambiente staging obligatorio antes de produccion.

5. Requerimientos funcionales por modulo

5.1 Autenticacion, usuarios y roles

Codigo	Requerimiento	Detalle	Prioridad
RF-AUT-01	Login/logout	Correo y contrasena con sesion segura.	Critico
RF-AUT-02	Recuperacion de contrasena	Token con vencimiento y uso unico.	Critico
RF-AUT-03	Bloqueo por intentos	Bloqueo temporal o captcha despues de intentos fallidos.	Alto
RF-AUT-04	Gestion de usuarios internos	Crear, editar, activar, inactivar y asignar roles.	Critico
RF-AUT-05	Usuario proveedor	Usuario vinculado obligatoriamente a un supplier_id.	Critico
RF-AUT-06	Auditoria de acceso	Login exitoso/fallido, cambio de rol, reset de contrasena.	Critico

5.2 Gestion de proveedores

Codigo	Requerimiento	Detalle	Prioridad
RF-PROV-01	Registro proveedor	Formulario con datos legales,	Critico

		tributarios y de contacto.	
RF-PROV-02	Carga documental	RUC, constancia tributaria, representante, declaraciones y terminos aceptados.	Crítico
RF-PROV-03	Estados	Pendiente, activo, observado, bloqueado, inactivo.	Crítico
RF-PROV-04	Homologacion manual	Compras/admin valida y habilita proveedor.	Crítico
RF-PROV-05	Rubros/categorias	Relacionar proveedor con categorias de bienes/servicios.	Alto
RF-PROV-06	Historial de cambios	Cambios de estado, documentos y datos relevantes.	Alto

5.3 Gestion de licitaciones

Codigo	Requerimiento	Detalle	Prioridad
RF-LIC-01	CRUD de licitacion	Crear, editar borrador, revisar y publicar.	Crítico
RF-LIC-02	Codigo unico	Formato sugerido: LIC-AAAA-NNNN.	Crítico
RF-LIC-03	Fechas	Publicacion, limite consultas, limite ofertas, evaluacion estimada.	Crítico
RF-LIC-04	Items/lotes	Items requeridos con cantidad, unidad, especificacion y lote.	Crítico
RF-LIC-05	Documentos base	Bases, anexos, planillas, condiciones y archivos tecnicos.	Crítico
RF-LIC-06	Addendas	Versionar cambios de documentos, plazos o condiciones.	Alto
RF-LIC-07	Estados	Borrador, revision, publicada, consultas cerradas, recepcion, cerrada, evaluacion, adjudicada, cancelada, desierta.	Crítico

5.4 Consultas y respuestas

Codigo	Requerimiento	Detalle	Prioridad
RF-CONS-01	Enviar pregunta	Proveedor habilitado pregunta dentro del plazo.	Crítico
RF-CONS-02	Responder pregunta	Compras responde o deriva internamente.	Crítico
RF-CONS-03	Anonimizacion	La respuesta no revela proveedor que consulto.	Crítico
RF-CONS-04	Cierre por fecha	No admitir consultas fuera del plazo.	Crítico
RF-CONS-05	Notificacion	Enviar correo cuando exista respuesta o addenda.	Alto

5.5 Presentacion de ofertas

Codigo	Requerimiento	Detalle	Prioridad
RF-OFER-01	Crear oferta	Formulario con datos generales, condiciones, items y adjuntos.	Crítico
RF-OFER-02	Items ofertados	Precio unitario, cantidad, subtotal, impuestos, total, marca/modelo opcional.	Crítico

RF-OFER-03	Envio definitivo	Confirmacion final con recibo de presentacion.	Critico
RF-OFER-04	Visibilidad interna inmediata	Usuarios internos autorizados ven la oferta desde el envio.	Critico
RF-OFER-05	Aislamiento proveedor	Proveedor solo ve sus propias ofertas y nunca datos de terceros.	Critico
RF-OFER-06	Reemplazo antes de cierre	Configurable por licitacion; conserva historial de versiones.	Alto
RF-OFER-07	Bloqueo fuera de plazo	Rechazo backend aunque el frontend falle.	Critico
RF-OFER-08	Auditoria de visualizacion	Toda vista/descarga interna de oferta queda registrada.	Critico

5.6 Evaluacion y adjudicacion

Codigo	Requerimiento	Detalle	Prioridad
RF-EVAL-01	Checklist documental	Cumple/no cumple documentos y requisitos minimos.	Critico
RF-EVAL-02	Evaluacion tecnica	Criterios con puntaje y observacion.	Critico
RF-EVAL-03	Evaluacion economica	Comparativo interno de precios, condiciones, plazos y garantias.	Critico
RF-EVAL-04	Ranking interno	Visible solo para usuarios internos autorizados.	Alto
RF-ADJ-01	Adjudicar	Seleccionar proveedor, monto, motivo y aprobador.	Critico
RF-ADJ-02	Cancelar/desierta	Registrar motivo obligatorio.	Critico
RF-ADJ-03	Comunicacion controlada	Notificar sin revelar terceros, ranking ni valores comparativos.	Critico

6. Requerimientos frontend

El frontend debe implementarse en React + TypeScript. El criterio principal no es solamente estetico: debe evitar errores de captura de ofertas, mostrar plazos con claridad y reducir acciones indebidas. Sin embargo, la seguridad real siempre debe estar en backend.

6.1 Pantallas proveedor

- Login y recuperacion de contrasena.
- Registro de proveedor.
- Mi perfil / datos legales.
- Mis documentos.
- Listado de licitaciones disponibles.
- Detalle de licitacion.
- Documentos publicados y addendas.
- Preguntas y respuestas.
- Formulario de oferta: datos generales, condiciones, items, archivos.
- Vista de mi oferta enviada.
- Recibo de presentacion.
- Comunicaciones y estado permitido del proceso.

6.2 Pantallas internas empresa

- Dashboard interno.
- Gestion de proveedores.
- Gestion de usuarios y roles.
- Crear/editar/publicar licitaciones.

- Gestion de documentos y addendas.
- Bandeja de consultas.
- Bandeja de ofertas recibidas.
- Detalle de oferta con items, valores y documentos.
- Evaluacion documental, tecnica y economica.
- Comparativo interno.
- Adjudicacion/cancelacion/desierta.
- Expediente y auditoria.

6.3 Componentes UI necesarios

Componente	Uso
Tabla paginada y filtrable	Licitaciones, proveedores, ofertas y logs.
Formulario dinamico	Licitacion, items y ofertas.
Uploader seguro	Carga con extension, tamano, progreso y mensajes claros.
Badges de estado	Proveedor, licitacion, oferta y evaluacion.
Modal de confirmacion	Envio de oferta, adjudicacion, cancelacion.
Timeline	Historial de licitacion y oferta.
Visor de documentos	Descarga o vista controlada segun permisos.
Matriz de evaluacion	Criterios, puntajes y observaciones.

7. Requerimientos backend y API

El backend debe construirse en TypeScript con NestJS. La estructura debe ser modular para separar cuentas, proveedores, licitaciones, documentos, consultas, ofertas, evaluaciones, adjudicaciones, auditoria y notificaciones.

7.1 Modulos NestJS recomendados

```
src/
  auth/
  users/
  roles/
  suppliers/
  tenders/
  tender-documents/
  questions/
  bids/
  evaluations/
  awards/
  audit/
  notifications/
  reports/
  files/
  common/
```

7.2 API minima

Endpoint base	Responsabilidad
/api/v1/auth	Login, logout, refresh/reset password.
/api/v1/users	Usuarios internos, proveedor y asignacion de roles.
/api/v1/suppliers	Registro, documentos, homologacion y estado.
/api/v1/tenders	Licitaciones, estados, items, criterios y publicacion.
/api/v1/tender-documents	Bases, anexos y addendas.
/api/v1/questions	Preguntas y respuestas.
/api/v1/bids	Ofertas, items, documentos y recibo.
/api/v1/evaluations	Checklist, puntajes y observaciones.
/api/v1/awards	Adjudicacion, cancelacion o desierta.
/api/v1/audit-logs	Consulta de eventos por auditoria.
/api/v1/files	Descarga controlada de documentos.
/api/v1/reports	Exportacion de expediente.

7.3 Validaciones backend obligatorias

- Validar rol y permiso en cada endpoint.
- Validar supplier_id del usuario proveedor contra el supplier_id de la oferta/documento solicitado.
- Validar fechas de consulta y cierre de ofertas en servidor.
- Validar estado de proveedor antes de permitir oferta.
- Validar estado de licitacion antes de permitir acciones.
- Validar extension, tamaño y tipo de archivos.
- Registrar audit_log en acciones criticas.
- No retornar datos de terceros por serializers/DTOs.
- No exponer rutas de almacenamiento interno.

8. Modelo de datos minimo

El modelo debe priorizar integridad, trazabilidad y consultas de auditoria. La estructura debe permitir evolucionar sin romper procesos cerrados.

Entidad	Proposito	Campos clave
User	Usuario del sistema	id, email, password_hash, name, status, last_login, supplier_id opcional
Role	Rol funcional	id, name, description
Permission	Permisos granulares	resource, action, scope
Supplier	Empresa proveedora	id, ruc, legal_name, trade_name, status, categories
SupplierDocument	Documentos proveedor	supplier_id, type, file_id, status, expires_at
Tender	Licitacion	code, title, status, dates, currency, buyer_id, requester_area
TenderItem	Items requeridos	tender_id, lot, description, unit, quantity, specs
TenderDocument	Bases/anexos/addendas	tender_id, type, version, file_id, published_at
Question	Pregunta proveedor	tender_id, supplier_id, user_id, text, status
Answer	Respuesta oficial	question_id opcional, text, published_at, author_id
Bid	Oferta	tender_id, supplier_id, user_id, version, status, submitted_at, validity, payment_terms
BidItem	Items ofertados	bid_id, tender_item_id, qty, unit_price, tax, total, notes
BidDocument	Archivos de oferta	bid_id, file_id, type, uploaded_at
EvaluationCriteria	Criterios	tender_id, category, weight, max_score
EvaluationScore	Puntajes	bid_id, criteria_id, evaluator_id, score, comment
Award	Adjudicacion/resultado	tender_id, supplier_id, amount, status, reason, approved_by
FileObject	Metadata de archivo	storage_path, original_name, mime, size, sha256, uploaded_by
AuditLog	Auditoria funcional	actor_id, role, ip, action, entity, entity_id, result, metadata

8.1 Relaciones criticas de seguridad

- User proveedor -> Supplier: relacion obligatoria para filtrar visibilidad.
- Bid -> Supplier -> Tender: toda oferta pertenece a un solo proveedor y una sola licitacion.
- BidItem -> Bid: los valores no deben consultarse fuera del contexto de permiso interno o proveedor propietario.
- FileObject -> entidad asociada: no debe existir descarga directa sin validar propietario/permiso.
- AuditLog -> entidades: debe permitir reconstruir eventos de publicacion, oferta, evaluacion y adjudicacion.

9. Seguridad, permisos y auditoria

El principal riesgo de este proyecto es la filtracion de informacion entre proveedores o la falta de evidencia sobre quien vio una oferta internamente. La Etapa 1 debe tratar permisos y auditoria como funcionalidad de negocio, no como complemento tecnico.

9.1 Matriz RBAC minima

Funcion	Admin	Compras	Area Solicitante	Eval. Tecnico	Eval. Economico	Aprobador	Auditor	Proveedor
Gestion usuarios	CRUD	No	No	No	No	No	Lectura	No
Gestion proveedores	CRUD	CRUD	Lectura	Lectura	Lectura	Lectura	Lectura	Propio
Crear licitacion	Si	Si	Solicita/edita alcance	No	No	No	Lectura	No
Publicar licitacion	Si	Si con aprobacion	No	No	No	Aprueba	Lectura	Ver publicadas
Preguntas	Ver/responder	Ver/responder	Colabora	Colabora	No	Lectura	Lectura	Propias
Ver oferta enviada	Si	Si	Segun permiso	Sin precios si aplica	Si	Si	Si	Solo propia
Evaluacion tecnica	Si	Lectura	Colabora	Edita	No	Lectura	Lectura	No
Evaluacion economica	Si	Lectura	No	No	Edita	Lectura	Lectura	No
Adjudicar/cerrar	Si	Propone	No	No	No	Aprueba	Lectura	No
Auditoria	Lectura	Limitada	No	No	No	Lectura	Completa	No

9.2 Eventos de auditoria obligatorios

Categoria	Eventos
Acceso	Login exitoso/fallido, logout, reset de contrasena, bloqueo.
Usuarios/roles	Creacion, modificacion, asignacion de rol, cambio de estado.
Proveedor	Registro, cambio de datos, documentos, homologacion, bloqueo.
Licitacion	Creacion, cambios, publicacion, cierre, addendas.
Documentos	Carga, descarga, anulacion logica, versionado.
Consultas	Pregunta enviada, respuesta publicada, cambio de estado.
Ofertas	Envio, reemplazo, visualizacion interna, descarga interna, intento denegado.
Evaluacion	Carga de puntaje, modificacion, cierre de evaluacion.
Resultado	Adjudicacion, cancelacion, desierta, comunicacion.
Reportes	Exportacion de expediente.

9.3 Controles minimos de seguridad

- **Autorizacion:** aplicar principio deny-by-default; cada endpoint debe declarar permisos requeridos.
- **Proveedor propietario:** todo acceso proveedor a ofertas/documentos debe filtrar por supplier_id.
- **Ofertas:** registrar visualizacion/descarga interna; no mostrar datos de otros proveedores bajo ninguna condicion.
- **Archivos:** allowlist de extensiones, validacion de tamano, renombrado, hash y almacenamiento fuera del webroot.
- **Entrada:** validar DTOs, tipos, longitudes, rangos, fechas y montos.
- **Errores:** no devolver stack traces ni informacion interna al cliente.
- **Sesiones/tokens:** expiracion definida, revocacion en logout/cambio de contrasena y secretos fuera de codigo.
- **Backups:** cifrados o protegidos, con restauracion probada.

10. Infraestructura, hardware y despliegue en Debian

El sistema operativo recomendado para el servicio es Debian stable. Para julio de 2026, la rama estable vigente es Debian 13 trixie, segun la informacion oficial de Debian. En la implementacion real debe verificarse nuevamente la version estable disponible antes del despliegue final.

10.1 Hardware minimo para piloto

Recurso	Minimo piloto
CPU	4 vCPU
RAM	8 GB
Disco sistema	80-100 GB SSD
Disco documentos	150-250 GB SSD/HDD empresarial
Red	IP publica o acceso por VPN; puertos 80/443 publicados
Backup	Copia local + copia externa/NAS/S3 compatible
UPS	Recomendado si es on-premise

10.2 Hardware recomendado para produccion inicial

Recurso	Recomendado produccion inicial
CPU	6-8 vCPU
RAM	16 GB
Disco sistema	100 GB SSD
Disco documentos	500 GB a 1 TB, segun volumen documental
Base de datos	PostgreSQL en el mismo host al inicio; preparar separacion futura
Backup	Diario DB + documentos, retencion minima 30/90 dias segun politica
Monitoreo	Zabbix, Uptime Kuma o equivalente
Firewall	Solo 80/443 publicos; SSH restringido por VPN/IP

10.3 Servicios en Docker Compose

Servicio	Responsabilidad
nginx	Reverse proxy HTTPS, cabeceras, limites de upload, static frontend.
frontend	Build estatico React/Vite o contenedor de publicacion.
backend	NestJS API ejecutado con Node.js LTS.
postgres	Base PostgreSQL con volumen persistente.
backup	Job programado para pg_dump y sincronizacion de archivos.
monitoring-agent	Agente Zabbix o exportador de metricas, si aplica.

10.4 Estructura sugerida en servidor Debian

```
/opt/licitaciones/
  docker-compose.yml
```

```

.env
nginx/
backend/
frontend/
postgres-data/      # volumen o mount controlado
storage/            # documentos privados fuera del webroot
backups/
logs/
scripts/

```

10.5 Reglas operativas del servidor

- Actualizar paquetes de seguridad de Debian mediante procedimiento controlado.
- Usar usuario sin privilegios para operacion de la aplicacion.
- No ejecutar contenedores con privilegios innecesarios.
- Separar secretos en .env protegido; no subir .env al repositorio.
- Forzar HTTPS en Nginx.
- Limitar tamano de upload segun politica documental.
- Registrar logs rotados para backend, nginx y jobs de backup.
- Probar restauracion en staging antes de dar produccion como aprobada.

11. Herramientas, aplicaciones y ambientes

11.1 Ambientes

Ambiente	Uso
Desarrollo local	Programadores levantan frontend, backend y PostgreSQL con Compose o servicios locales.
Staging	Ambiente de prueba con datos ficticios o anonimizados; obligatorio para QA y restauracion.
Produccion	Ambiente real con HTTPS, backups, monitoreo y acceso restringido.

11.2 Herramientas de desarrollo

Herramienta	Uso
Git	Control de versiones.
GitHub/GitLab	Repositorio, issues, pull requests, CI/CD basico.
Node.js LTS + npm/pnpm	Runtime y gestion de paquetes TypeScript.
TypeScript strict	Tipado estricto para frontend/backend.
NestJS CLI	Estructura y generacion de modulos backend.
Prisma CLI	Migraciones y cliente de base de datos.
Postman/Insomnia	Pruebas manuales de API.
Playwright/Cypress	Pruebas end-to-end.
Vitest/Jest	Pruebas unitarias frontend/backend.
DBeaver/pgAdmin	Inspeccion controlada de PostgreSQL.

11.3 Herramientas de operacion

Herramienta	Uso
Nginx	Reverse proxy y TLS.
Docker Compose	Ejecucion multi-contenedor.
Certbot o certificado corporativo	Certificados HTTPS.
Zabbix/Uptime Kuma	Monitoreo de disponibilidad, CPU, RAM, disco, certificados y servicios.
pg_dump/pg_restore	Backup y restauracion de PostgreSQL.
rsync/restic/borg	Copia y retencion de archivos documentales.
UFW/nftables	Firewall del host.

12. Plan de ejecucion por fases y sprints

La primera etapa puede ejecutarse en 8 a 10 sprints de trabajo, dependiendo del equipo. La duracion real debe estimarse segun cantidad de desarrolladores y disponibilidad de usuarios de negocio para validar.

Fase	Nombre	Trabajo principal	Entregable
Fase 0	Preparacion funcional	Roles, estados, reglas, documentos, matriz de permisos, wireframes y backlog.	Documento funcional cerrado.
Fase 1	Base tecnica	Repositorios, Docker Compose, NestJS, React, PostgreSQL, Prisma, Nginx staging.	Proyecto levantado en local/staging.
Fase 2	Usuarios y proveedores	Auth, usuarios, roles, registro proveedor, documentos, homologacion.	Proveedor puede registrarse y ser habilitado.
Fase 3	Licitaciones	CRUD licitacion, items, documentos, estados, publicacion.	Proveedor habilitado puede ver licitacion y bases.
Fase 4	Consultas	Preguntas, respuestas, anonimizacion, notificaciones.	Consultas dentro del portal.
Fase 5	Ofertas	Carga de oferta, items, archivos, recibo, visibilidad interna inmediata, aislamiento.	Oferta enviada y protegida.
Fase 6	Evaluacion y adjudicacion	Checklist, puntajes, comparativo, adjudicar/cancelar/desierta.	Proceso puede cerrarse.
Fase 7	Auditoria y reportes	Logs, expediente, backup, restauracion y monitoreo.	Piloto listo para produccion controlada.

12.1 Backlog priorizado

Prioridad	Incluye
P0	Permisos/RBAC, autenticacion, supplier_id isolation, carga de oferta, bloqueo por fechas, auditoria de ofertas, backups.
P1	Registro proveedor, homologacion manual, licitaciones, documentos, consultas, evaluacion basica, adjudicacion.
P2	Notificaciones, addendas versionadas, exportacion expediente, dashboard basico, filtros avanzados.
P3	Mejoras UX, reportes adicionales, parametrizacion fina, plantillas de documentos.

13. Pruebas, criterios de aceptacion y salida a produccion

13.1 Pruebas funcionales obligatorias

16. Crear proveedor y cargar documentos.
17. Habilitar proveedor desde usuario interno.
18. Crear licitacion con items, documentos y fechas.
19. Publicar licitacion.
20. Proveedor descarga documentos publicados.
21. Proveedor envia pregunta dentro del plazo.
22. Compras responde sin exponer identidad del proveedor.
23. Proveedor presenta oferta con items, valores y archivos.
24. Empresa visualiza internamente la oferta inmediatamente.
25. Otro proveedor intenta ver la oferta y el sistema lo bloquea.
26. Sistema bloquea oferta fuera del plazo.

27. Evaluador registra evaluacion tecnica/economica.
28. Aprobador adjudica, cancela o declara desierta.
29. Proveedor recibe comunicacion sin datos de terceros.
30. Auditor revisa bitacora y expediente.
31. Se restaura backup en staging.

13.2 Pruebas de seguridad minimas

- Proveedor A no puede acceder por API a ofertas, documentos o consultas privadas de Proveedor B.
- Usuario no autenticado no descarga archivos privados.
- Proveedor no puede cambiar supplier_id en payload para suplantar a otro.
- Evaluador tecnico sin permiso economico no ve valores si se decide separar vista tecnica.
- Usuario interno sin rol de ofertas no puede abrir ofertas.
- Toda visualizacion interna de oferta genera audit_log.
- Archivos con extension no permitida se rechazan.
- Payloads con fechas/precios invalidos se rechazan en backend.
- Errores 403/404 no filtran existencia de recursos de terceros.

13.3 Criterios de salida a produccion

- Se puede ejecutar una licitacion piloto completa de inicio a cierre.
- Las pruebas de aislamiento entre proveedores pasan sin excepciones.
- Backups y restauracion fueron probados con evidencia.
- El servidor Debian esta actualizado y endurecido minimamente.
- Nginx publica solo HTTPS y restringe tamanos de carga.
- Los logs de auditoria muestran acciones criticas.
- Hay manual operativo basico para usuarios internos y proveedores.
- Se cuenta con politica interna de uso, confidencialidad y tratamiento de ofertas.

14. Preparacion para etapas 2, 3 y 4

Aunque la Etapa 1 no implementa funcionalidades avanzadas, debe dejar puntos de extension para no rehacer el sistema en fases posteriores.

Etapa futura	Eje	Preparar desde Etapa 1
Etapa 2	Seguridad y operacion ampliada	MFA, antivirus de archivos, MinIO/S3, alertas, mejores reportes, parametros avanzados, retencion documental.
Etapa 3	Integracion y automatizacion	Integracion con ERP/SAP, ordenes de compra, aprobaciones configurables, catalogo de proveedores, flujos de aprobacion.
Etapa 4	Gobierno avanzado	Analitica, KPIs, scorecard de proveedores, contratos, BI, auditoria inmutable, alta disponibilidad.

14.1 Decisiones que facilitan la evolucion

- Usar modulos backend separados desde el inicio.
- Usar migraciones Prisma versionadas.
- No acoplar archivos al disco local: crear servicio de storage interno que luego pueda apuntar a S3/MinIO.
- Centralizar permisos en guards/policias para agregar roles sin reescribir endpoints.
- Usar codigos y estados parametrizables cuando corresponda.
- Guardar auditoria en entidad separada para futuros reportes o almacenamiento inmutable.
- Usar API versionada para integraciones futuras con SAP/ERP.

15. Fuentes oficiales consultadas

Las siguientes fuentes oficiales respaldan las decisiones tecnicas y de seguridad usadas como referencia. Antes de iniciar despliegue productivo, conviene verificar versiones actuales de cada tecnologia.

ID	Fuente oficial	URL
F1	Debian - Releases	https://www.debian.org/releases/
F2	Debian 13 trixie - Release Information	https://www.debian.org/releases/stable/

F3	TypeScript Handbook	https://www.typescriptlang.org/docs/handbook/intro.html
F4	React - Using TypeScript	https://react.dev/learn/typescript
F5	NestJS - First Steps	https://docs.nestjs.com/first-steps
F6	PostgreSQL Documentation	https://www.postgresql.org/docs/
F7	Prisma ORM Documentation	https://www.prisma.io/docs/orm
F8	Prisma ORM with PostgreSQL Quickstart	https://www.prisma.io/docs/prisma-orm/quickstart/postgresql
F9	Docker Compose Documentation	https://docs.docker.com/compose/
F10	Docker Compose in Production	https://docs.docker.com/compose/how-tos/production/
F11	NGINX Reverse Proxy Documentation	https://docs.nginx.com/nginx/admin-guide/web-server/reverse-proxy
F12	OWASP ASVS	https://owasp.org/www-project-application-security-verification-standard/
F13	OWASP Authorization Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
F14	OWASP File Upload Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
F15	NIST SP 800-63-4 Digital Identity Guidelines	https://www.nist.gov/publications/nist-sp-800-63-4-digital-identity-guidelines
F16	PostgreSQL pg_dump Documentation	https://www.postgresql.org/docs/current/app-pgdump.html

Cierre ejecutivo

Para avanzar correctamente, la primera decision de desarrollo debe ser blindar permisos, supplier_id isolation y audit_log. Luego se debe construir la funcionalidad de licitaciones, documentos, consultas y ofertas. El portal puede comenzar con infraestructura simple sobre Debian, TypeScript y PostgreSQL, siempre que la operacion incluya staging, backups, HTTPS, monitoreo y pruebas de restauracion. La prueba mas importante de la Etapa 1 no es visual: es demostrar que un proveedor nunca puede ver datos de otro proveedor, mientras la empresa si puede ver una oferta desde el momento en que fue enviada.